



Conceitos Fundamentais

Segurança em Redes e Sistemas Informáticos

CTeSP em Redes e Sistemas Informáticos

Escola Superior de Tecnologia e Gestão de Águeda

Universidade de Aveiro

2024-25



Objetivos

- Porquê a necessidade de segurança?
- Conceitos de Segurança da Informação x Cibersegurança x Segurança em Redes e Sistemas.
- Proteger o quê? Conceito de Ativo (*asset*).
- Conceitos de ameaça, vulnerabilidade e risco.
- Objetivos de Segurança. Tríade CIA e objetivos adicionais



Necessidade de segurança

- Se falamos em segurança, da necessidade de segurança, é porque nos sentimos ameaçados, porque nos vemos rodeados de ataques.
- Com quê?
- Porquê?
- A quê?



Alguns ataques ...

P SOCIEDADE EDUCAÇÃO SAÚDE JUSTIÇA MEDIA FLORESTAS PÚBLICO NA ESCOLA MAIS ▾

POLÍCIA JUDICIÁRIA

Burlões informáticos conseguiram enganar 5100 idosos suecos a partir de Portugal

Com ajuda da Europol e do Eurojust, Polícia Judiciária deteve nesta terça-feira seis dezenas e meia de pessoas em megaoperação. Esquema rendeu mais de 14 milhões de euros em dois anos.

Ana Henriques
16 de Setembro de 2025, 17:39



<https://www.publico.pt/2025/09/16/sociedade/noticia/burloes-informaticos-conseguiram-enganar-5100-idosos-suecos-partir-portugal-214742>

1



Mais ...

Cyber Security News

[Home](#) [Threats](#) [Cyberattack News](#) [Vulnerability](#) [Zero-Day](#) [Data Breaches](#) [Cyber AI](#) [CyberPedia](#)

[Top 10](#)

[Home](#) > [Cyber Security News](#) > 224 Malicious Android Apps on Google Play With 38 Million Downloads Delivering...

[Cyber Security News](#) [Threats](#)

224 Malicious Android Apps on Google Play With 38 Million Downloads Delivering Malicious Payloads

By [Tushar Subhra Dutta](#) - September 17, 2025



[Top 10](#)

**Top 10 Best Security Orchestration, Automation, And Response (SOAR) Tools**

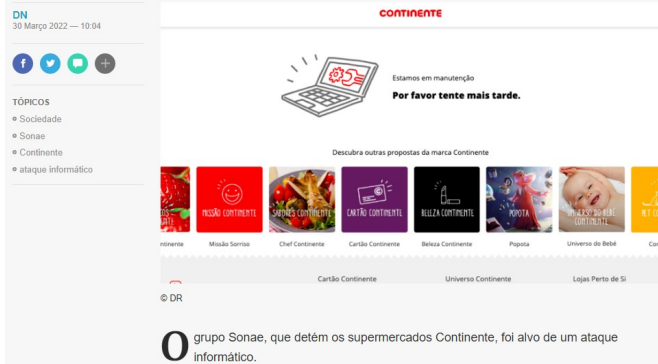
- <https://cybersecuritynews.com/224-malicious-android-apps-on-google-play/>



Outros ainda ...

Grupo Sonae, que detém os supermercados Continente, alvo de ataque informático

Não é possível aceder à página online dos supermercados Continente.



Cofina. PJ investiga suspeita de ciberataque a sites do grupo

SÓNIA PERES PINTO
06/02/2022 15:45

© Miguel Silva



Ao início da tarde, os sites CM, CMTV e Record voltaram a estar online. PJ diz que “não está comprovado” que ataque informático tenha sido causado pela organização Lapsus\$, que atacou grupo Impresa.

Ministério dos Negócios Estrangeiros alvo de ciberataque

ECO
23 Fevereiro 2022



Ministério dos Negócios Estrangeiros foi alvo de um ataque informático. Santos Silva assegura que a “informação não está comprometida”.



Ataque à Vodafone. O que foi afectado e o que já está resolvido?

O ciberataque à operadora Vodafone levou a cabo desde o final da noite de segunda-feira tem provocado várias falhas nos sistemas, afectando serviços como os Bombeiros, a rede Multibanco, o INEM e até alguns hospitais. Já foi iniciado o restabelecimento do serviço 4G.

Mariana Marques Tiago
8 de Fevereiro de 2022, 15:15 (actualizado a 8 de Fevereiro de 2022, 21:22)

O leitor alertas



Laboratórios Germano de Sousa alvo de ciberataque. CUF cancela testes à covid-19

“Não existe qualquer evidência de que os dados dos nossos doentes tenham sido comprometidos”, diz o laboratório em comunicado.

DN
19 Fevereiro 2022 — 12:49

O leitor alertas

TÓPICOS
• Cibersegurança
• Sociedade
• Germano de Sousa
• CUF



O laboratório Germano de Sousa foi alvo de um ataque informático durante a noite desta quarta-feira. O laboratório de análises emitiu um comunicado na tarde desta quinta-feira a informar que “na madrugada do dia 10 de fevereiro de 2022, foi alvo de um ciberataque deliberado e criminoso com o objetivo de causar danos e perturbações à sua atividade e aos seus doentes”.

Almada

Hospital Garcia de Orta foi alvo de ciberataque

Rogério Matos

Hoje às 13:18



COMENTAR

TÓPICOS

Concelho Almada

Local

Justiça



Hospital Garcia de Orta, em Almada
Foto: Carlos Santos / Arquivo Global Imagens

O Hospital Garcia de Orta, em Almada, foi alvo de um ciberataque, esta terça-feira.

Em comunicado, a unidade hospitalar de Almada refere ter ativado o protocolo de segurança, “entrando em contacto com o Centro Nacional de Cibersegurança (CNCS) que já está a acompanhar a situação”.



Muito recentes e em Portugal (2)

TAP

TAP alerta clientes afectados por ciberataque para “risco de uso ilegítimo” de dados

Num email enviado aos clientes, a companhia indicou que “foram tomadas de imediato medidas de contenção e remediação para proteger os dados”.

Lusa e PÚBLICO

13 de Setembro de 2022, 20:43



<https://www.publico.pt/2022/09/13/sociedade/noticia/tap-alerta-clientes-afectados-ciberataque-risco-uso-ilegitimo-dados-2020464>



Muito recentes e em Portugal (4)

CIBERCRIME

***Hackers* atacam Estado-Maior-General das Forças Armadas e colocam documentos da NATO à venda na internet**

O primeiro-ministro, António Costa, alegadamente só soube do caso porque foi informado pelos serviços secretos dos Estados Unidos.

PÚBLICO

8 de Setembro de 2022, 10:11



<https://www.publico.pt/2022/09/08/sociedade/noticia/piratas-atacam-estadomaiorgeneral-forcas-armadas-colocam-documentos-nato-venda-internet-2019803>



Politécnico de Beja vítima de fraude informática! Roubados 50 mil euros

02 JUL 2024 · INTERNET

15 COMENTÁRIOS

Há mais uma vítima de um ataque "CEO Fraud". Segundo as informações, o Politécnico de Beja foi vítima de fraude informática, tendo os burlões conseguido "roubar" 50 mil euros. Saiba como o esquema funcionou.

<https://pplware.sapo.pt/internet/politecnico-de-beja-vitima-de-fraude-informatica-roubados-50-mil-euros/>



TECNOLOGIA REDES SOCIAIS PRIVACIDADE INTELIGÊNCIA ARTIFICIAL TELEMÓVEIS GOOGLE FACEBOOK MAIS ▾

CIBERSEGURANÇA

16 mil milhões de *passwords* reveladas, incluindo do Gmail, Facebook e Apple

Especialistas aconselham actualização de palavras-passe. Não é claro se as bases de dados descobertas partem de fugas de informação antigas ou mais recentes.

PÚBLICO

21 de Junho de 2025, 22:16



- <https://www.publico.pt/2025/06/21/tecnologia/noticia/16-mil-milhoes-passwords-reveladas-incluindo-gmail-facebook-apple-2137432>



P TECNOLOGIA REDES SOCIAIS PRIVACIDADE INTELIGÊNCIA ARTIFICIAL TELEMÓVEIS GOOGLE FACEBOOK MAIS ▾

EXCLUSIVO CIBERSEGURANÇA

Dados de clientes da Generali Tranquilidade comprometidos em ciberataque

Numa mensagem enviada aos clientes, a Generali Tranquilidade confirmou que identificou “recentemente um acesso não autorizado a dados de clientes”.

Sérgio Magno
24 de Junho de 2025, 18:35

- <https://www.publico.pt/2025/06/24/tecnologia/noticia/dados-clientes-general-tranquilidade-comprometidos-ciberataque-2137713>



Mais ...



- <https://www.publico.pt/2025/07/30/enter/noticia/fabricante-brinquedos-sexuais-lovense-expoe-dados-privados-clientes-2142202>



- <https://www.publico.pt/2025/08/11/enter/noticia/google-detecta-aumento-ciberataques-roubo-credencias-gmail-2143602>



Crimes no ciberespaço português aumentaram em 2023

O relatório do Observatório de Cibersegurança revela que as autoridades registaram, em 2023, 2512 crimes informáticos, enquadrados pela Lei do Cibercrime, mais 13% do que em 2022.

Lusa

5 de Julho de 2024, 14:43



Os ataques com mais impacto foram de ransomware e afectaram a administração pública local KACPER



Mais ...

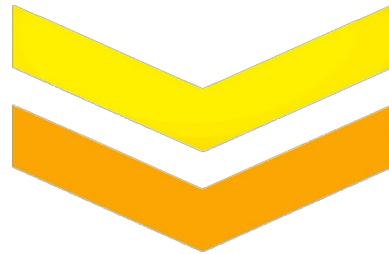


- <https://www.publico.pt/2025/09/16/sociedade/noticia/incidentes-ciberseguranca-registados-2024-sobem-36-2758-2147402>

Antes ...



Agora ...



... no Ciberespaço





Novas tecnologias

- Novas tecnologias no ciberespaço
 - Mais informação digital
 - Mais valor no ciberespaço
- E onde há valor ...





Ciberespaço

- ENSC – Estratégia Nacional de Segurança do Ciberespaço 2019-2023
 - Resolução de Conselho de Ministros N.º 92/2019
 - <https://www.cncs.gov.pt/docs/cncs-ensc-2019-2023.pdf>
- Ciberespaço consiste no ambiente complexo, de valores e interesses, materializado numa área de responsabilidade coletiva, que resulta da interação entre pessoas, redes e sistemas de informação.
 - ENSC: <https://www.cncs.gov.pt/docs/cncs-ensc-2019-2023.pdf>



Cibersegurança

- Conjunto de medidas e ações de prevenção, monitorização, deteção, reação, análise e correção que visam manter o estado de segurança desejado e garantir a confidencialidade, integridade, disponibilidade e não repúdio da informação, das redes e sistemas de informação no ciberespaço, e das pessoas que nele interagem
 - ENSC: <https://www.cnsc.gov.pt/docs/cnsc-ensc-2019-2023.pdf>
- Não consegue impedir a totalidade dos ataques, ou garantir que um sistema seja totalmente seguro
- O objetivo é garantir que as medidas de proteção são implementadas de forma adequada para evitar ataques e evitar o colapso total do sistema quando ocorre um ataque com sucesso

Segurança da Informação x Cibersegurança x Segurança em Redes e Sistemas



- Designações, mais ou menos sinónimo, mas com âmbito e enfoque diferentes: Segurança da Informação (*Information Security*), Cibersegurança, *Computer Security* ou Segurança de Redes e Sistemas.
- Segurança da Informação (*Information Security*): A mais abrangente das três. Tem como objetivo proteger a informação enquanto um recurso essencial para o negócio, independentemente do formato (digital, física, verbal, etc.)
 - Como podemos proteger a informação e garantir que ela está segura em todos os seus estados e formatos?
- Cibersegurança (*Cybersecurity*): É um subconjunto da segurança da informação, focado em proteger os sistemas e dados digitais contra ameaças e ataques provenientes do ciberespaço.
 - Como é que os atacantes pensam e atacam os nossos sistemas, e como podemos defender-nos de forma eficaz?
- Segurança de Redes e Sistemas: É ainda mais específica. Foca-se em garantir que a infraestrutura técnica onde os sistemas e redes operam esteja bem configurada, segura e protegida contra falhas ou ataques.
 - Como podemos garantir que a infraestrutura e os sistemas estão bem configurados, seguros e protegidos contra falhas ou intrusões?



Proteger o quê? Ativos

- **Ativo:** Qualquer coisa (tudo) que tem valor para uma organização ou indivíduo e deve ser protegido
- Se não sabemos quais são os ativos, não conseguimos definir prioridades de segurança
- Dois tipos de ativos:
 - Ativos tangíveis: servidores, computadores, ...
 - Ativos intangíveis: informação, reputação, propriedade intelectual,...



Categorias de Ativos

- **Informação:** dados pessoais, bases de dados, planos de negócio, código-fonte.
- **Infraestruturas tecnológicas:** hardware, software, redes, dispositivos móveis, serviços em cloud.
- **Pessoas:** utilizadores, administradores, parceiros;
 - também conhecimento e competências.
- **Processos de negócio:** serviços críticos, imagem da empresa, confiança de clientes.
- Exemplo com o caso da Universidade:
 - notas dos alunos (informação),
 - sistemas académicos (infraestrutura),
 - professores/estudantes (pessoas),
 - reputação institucional (processo/valor intangível)



Atividade

- Em pares, listem 3 ativos pessoais e 3 ativos de uma organização.
- Se um ativo for comprometido, qual o impacto?
- Segurança informática protege ativos de valor contra ameaças
 - Mas proteger tudo é impossível!
 - Precisamos de medir **qual é o risco** de cada ativo.

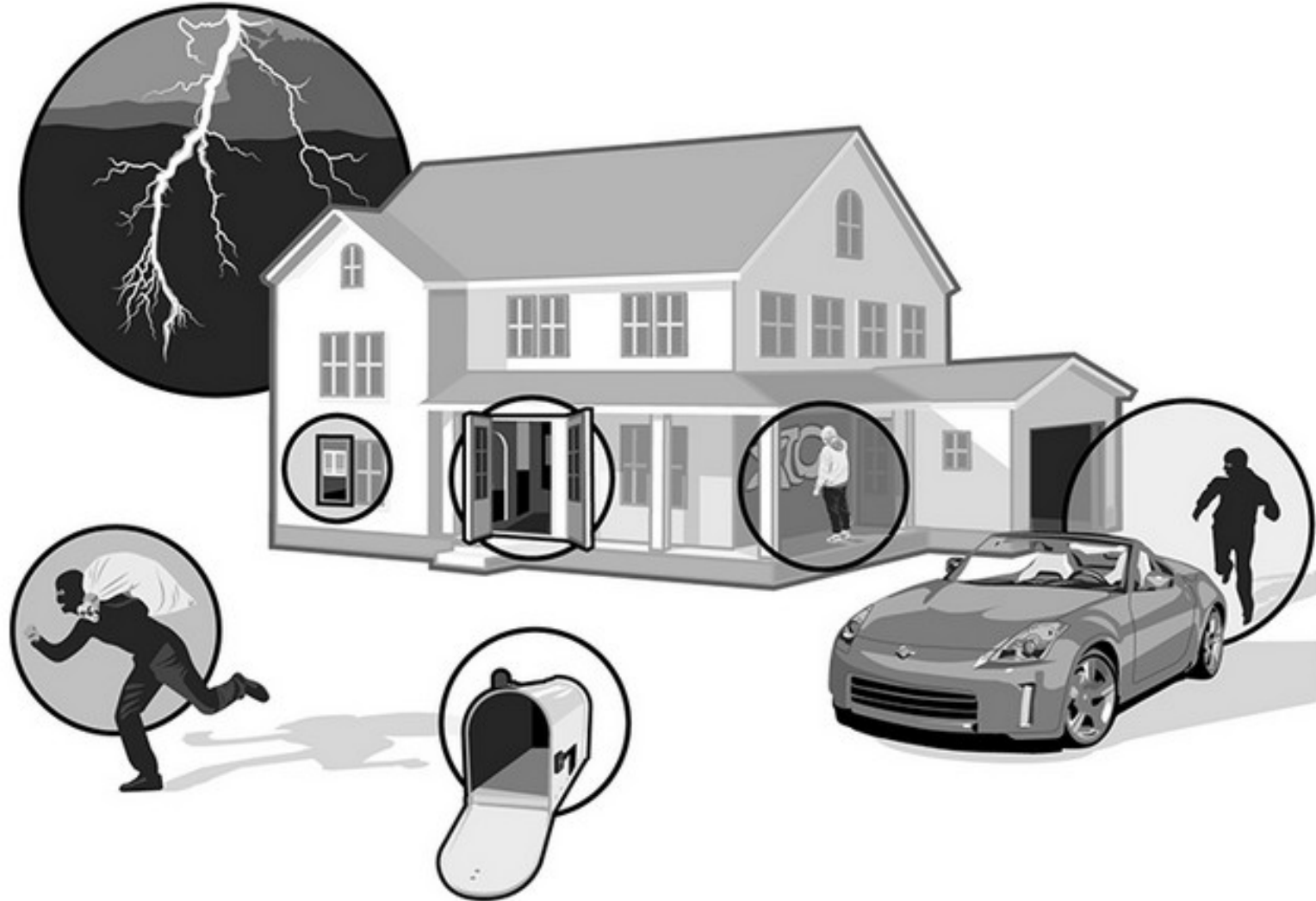


Conceitos de Ameaça e Vulnerabilidade

- Ameaça (*threat*):
 - Agente ou evento que pode causar dano.
 - Algo ou alguém que pode explorar uma falha e causar dano.
- Vulnerabilidade:
 - Fraqueza que pode ser explorada.
 - Falha ou ponto fraco que permite a concretização de uma ameaça



Ameaças e vulnerabilidades





Conceito de Risco

- O risco está onnipresente no nosso dia-a-dia
- Risco é uma situação que envolve a exposição a algum tipo de perigo
 - Possibilidade de uma ameaça explorar uma vulnerabilidade com impacto negativo
 - **Probabilidade x Impacto**
 - Análise quantitativa quando se consegue atribuir valores
 - Análise qualitativa, quando é difícil atribuir valores
 - Maior ou menor dependente de:
 - Da probabilidade de concretização de uma ameaça
 - Do valor do dano (impacto) causado pela concretização dessa ameaça
- Uma circunstância ou um evento razoavelmente identificável, com um efeito adverso potencial na segurança das redes e dos sistemas de informação. (Lei 46/2018)



Atividade

- Nos seguintes cenários, identifique os ativos, as ameaças, as vulnerabilidades e o risco.
 - Um estudante deixa o portátil sem password numa biblioteca.
 - Uma empresa guarda dados pessoais de clientes num servidor interno sem encriptação.



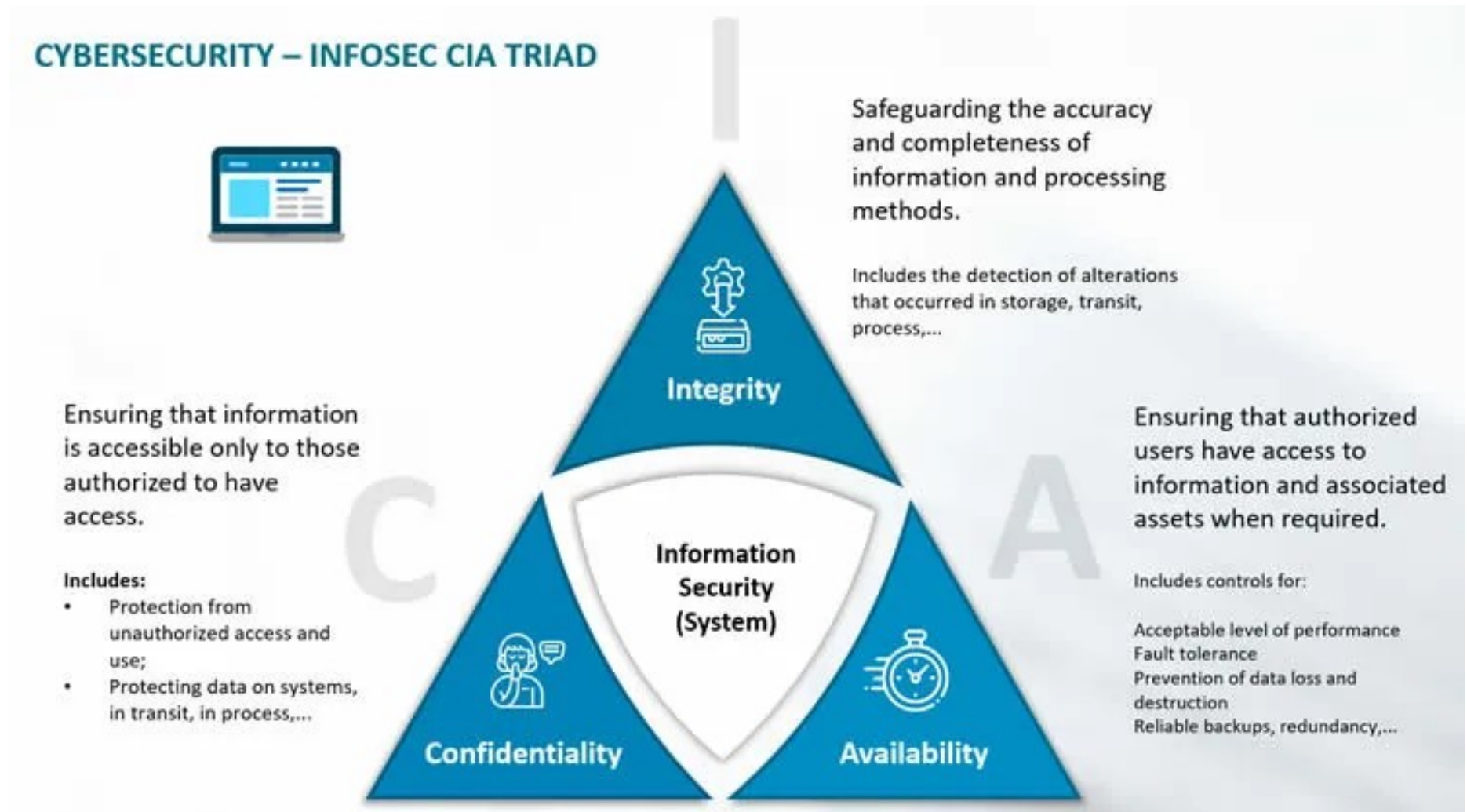
Principais objetivos de segurança

- São três os principais objetivos de segurança (CIA):
 - Confidencialidade (*Confidentiality*): garantir que a informação apenas pode ser vista por quem está autorizado
 - Integridade (*Integrity*): garantir que a informação está correta e não sofreu alterações
 - Disponibilidade (*Availability*): garantir que a informação está disponível quando é necessária para quem está autorizado a aceder-lhe
- Como a informação está armazenada em hardware, é manipulada por software e é transmitida por sistemas de comunicações, implica ter de se garantir também a integridade, confidencialidade e disponibilidade dos dispositivos que a armazenam manipulam e transmitem

<https://pplware.sapo.pt/truques-dicas/importancia-da-triade-c-i-a-no-espaco-da-ciberseguranca/>



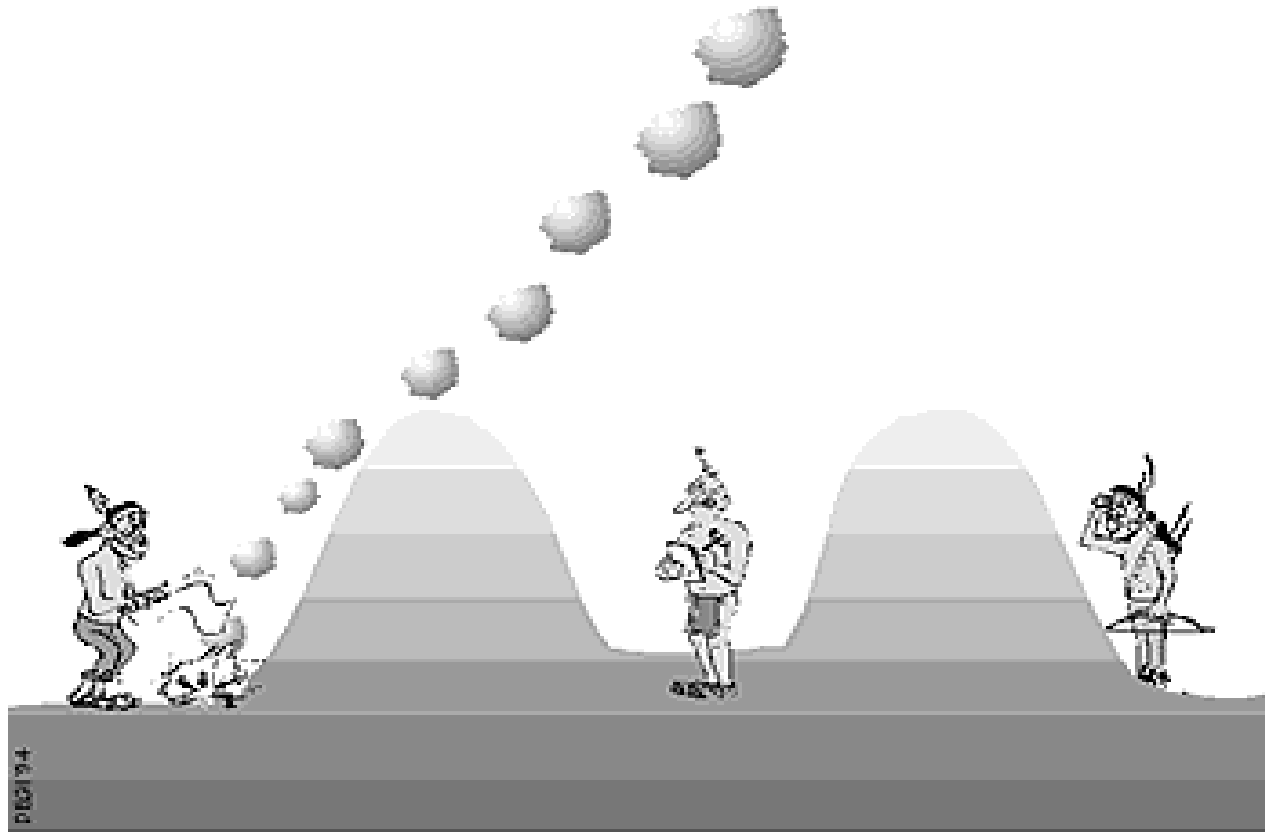
CIA Triad (Tríade CIA)





Confidencialidade

- A leitura de uma informação apenas deve ser feita por quem está autorizado para o fazer

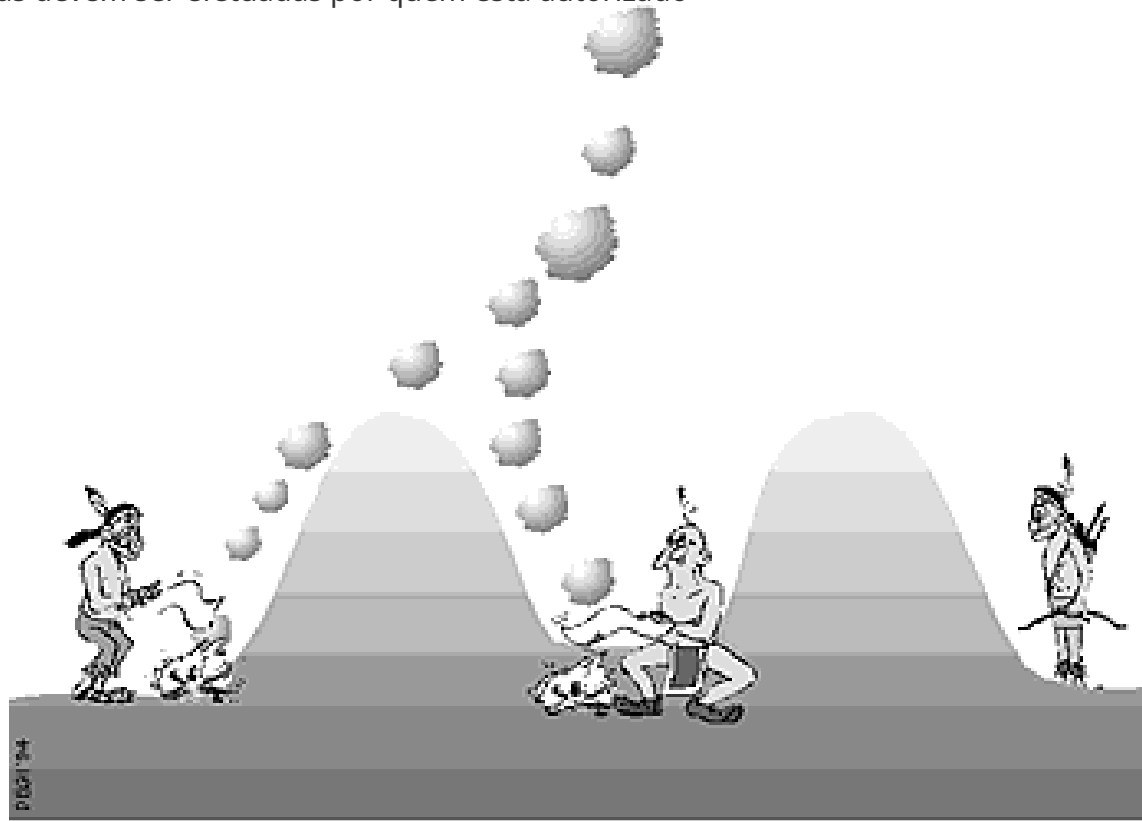


Retirado de: <http://www.esat.kuleuven.be/cosic/intro>



Integridade

- Garantir que um ativo está íntegro.
 - Garantir que os dados não foram alterados de nenhuma forma
- Alterações apenas devem ser efetuadas por quem está autorizado



Retirado de: <http://www.esat.kuleuven.be/cosic/intro>



Disponibilidade

- Manter um recurso disponível para ser acedido:
 - Por quem está autorizado
 - Quando ele é necessário
- Não se refere a tornar o recurso indisponível para as entidades não autorizadas: controlo de acesso





Equilíbrio na Tríade CIA

- A segurança da informação não consiste em maximizar apenas um dos pilares.
- Se dermos prioridade absoluta a um pilar, podemos comprometer os outros dois.
- O desafio é encontrar um equilíbrio aceitável entre os três, ajustado ao contexto (empresa, serviço, utilizador).



Exemplos de Desequilíbrio

- Confidencialidade demasiado forte
 - Sistema exige autenticação multifator com tokens físicos para tudo → muito seguro, mas torna-se pouco prático → quebra da Disponibilidade.
 - Ex.: hospital onde médicos não conseguem aceder rapidamente a dados do paciente em emergência.
 - Disponibilidade extrema
 - Serviço está sempre acessível, sem restrições de autenticação → fácil acesso, mas fraca proteção → compromete a Confidencialidade.
 - Ex.: base de dados exposta online sem password.
 - Integridade rígida
 - Mecanismos de validação e logging demasiado pesados → tornam os sistemas lentos → prejudicam a Disponibilidade.
 - Ex.: software que exige validações constantes, atrasando operações críticas.
-



Tríade CIA: aplicação

- A tríade CIA não é estática. Em cada sistema temos de decidir:
 - Quais ativos precisam de mais confidencialidade?
 - Quais operações não podem parar (disponibilidade máxima)?
 - Quais dados não podem ser alterados de forma nenhuma (integridade total)?



Objetivos Complementares da Segurança

- Autenticidade: Garantir que algo ou alguém é real e legítimo
- Não repúdio: Impedir que alguém negue uma ação



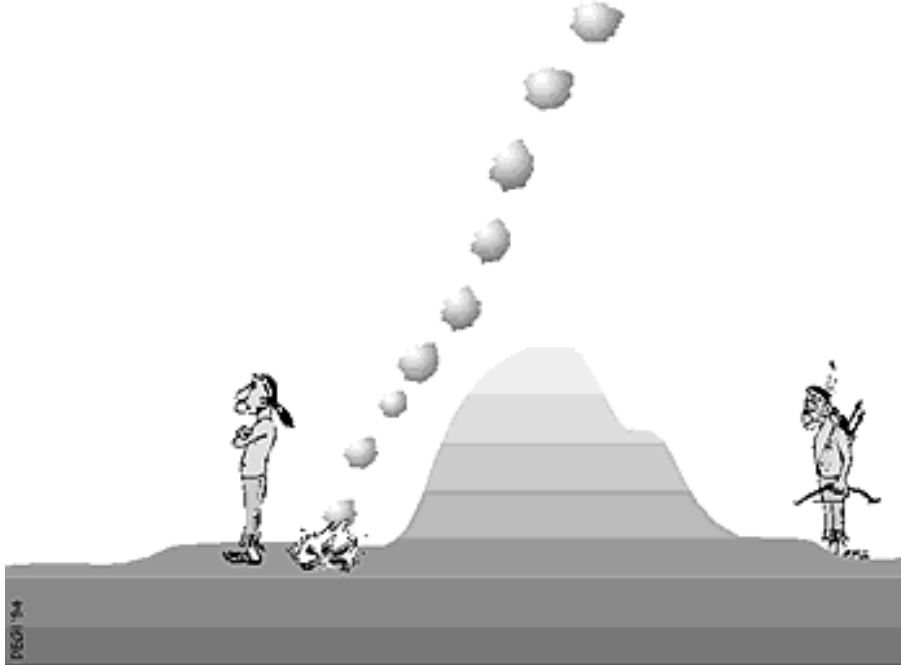
Autenticidade

- Garantia de que uma informação, mensagem ou entidade é real, legítima e confiável.
- Evita falsificação ou alteração da origem.
- Exemplos:
 - Certificado digital que prova que um site é realmente de um banco.
 - Assinatura digital que confirma que um contrato foi assinado pelo responsável certo.



Objetivo Complementar: Não Repúdio

- Impedir que uma entidade neque uma ação que realizou



Retirado de: <http://www.esat.kuleuven.be/cosic/intro>

- Exemplos:
 - Assinaturas digitais em contratos eletrónicos.
 - Logs de sistema protegidos.
 - Envio de e-mail assinado digitalmente.

- Relação com CIA:
 - Reforça Integridade (provas de que os dados não foram alterados).
 - Apoia Confidencialidade (garante autenticidade da origem).



Atividade em grupo

- Cenários:
 - Site de comércio eletrônico fica offline após ataque de DDoS
 - Colaborador copia base de dados de clientes para pen-drive pessoal
 - Aluno altera notas na base de dados académica
 - Cliente nega compra feita online
- Para cada cenário, identificar:
 - Ativo
 - Ameaça
 - Vulnerabilidade
 - Risco
 - Objetivo de segurança comprometido



-
- Como garantimos que o acesso aos ativos apenas é feito pelas pessoas certas?
 - Controlos de Segurança

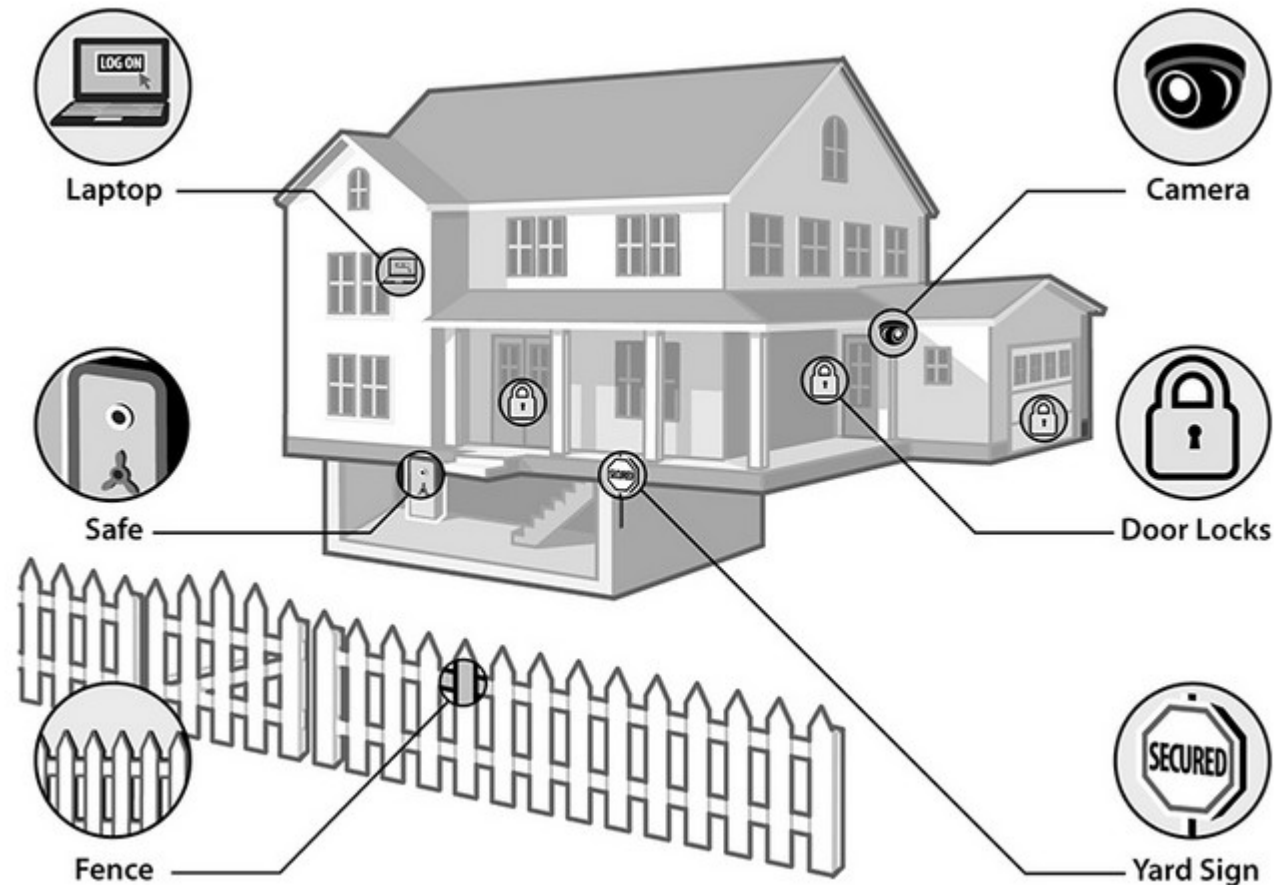


Controlos de Segurança

- São um componente essencial em qualquer estratégia de segurança informática
- Qualquer medida, política, procedimento ou prática implementada para proteger ativos de uma organização contra ameaças, vulnerabilidades e riscos de segurança.
- Tudo o que uma organização faz para garantir a confidencialidade, integridade, disponibilidade, e a resposta adequada a incidentes.



Controlos de Segurança



- Processos ou tecnologias colocadas para proteger a confidencialidade, integridade e disponibilidade dos ativos (sistemas, informação, ...)
 - Também designados por: medidas, contra-medidas, proteções



Categorias de Controlos de Segurança

- Administrativos (ou organizacionais)
 - Relacionados com a gestão de risco, alinhamento estratégico e tomadas de decisão
 - Exemplos: Políticas de Segurança, Procedimentos, Classificação de Informação, Planos de Resposta a Incidentes (IRP – Incident Response Plan), Planos de Continuidade de Negócio (BCP – Business Continuity Plan), Treino das pessoas
- Técnicos (ou Lógicos)
 - Implementados usando tecnologia (componentes de hardware ou software)
 - Criptografia, Antivírus, Firewall, Sistemas de Detecção/Prevenção de Intrusões (IDS/IPS), Sistemas de Autenticação
- Físicos
 - Concebidos para lidar com interações físicas. Relacionados com edifícios e equipamento
 - Barreiras, Câmaras de Vigilância, Portões, Guardas, Fechaduras



Tipos de Controlos de Segurança

- Prevenção (*Preventive*)
 - Impedir que os incidentes de segurança ocorram.
 - Firewall, Criptografia, Sistemas de Controlo de Acesso.
- Dissuasão (*Deterrent*)
 - Desencorajar a ação de atacantes ou comportamentos impróprios.
 - Sinalização, Camaras de Vigilância, Guardas
- Detecção (*Detective*)
 - Detetar ou identificar incidentes de segurança em tempo real ou logo após ocorrerem
 - Camaras de Vigilância, IDS/IPS (Sistemas de Detecção/Proteção de Intrusões), SIEM (Security Information Event Management)
- Correção (*Corrective*)
 - Corrigir ou mitigar os efeitos de um incidente ou falha
 - Backup/restore, aplicar patches, IRP (Incident Response Plan).
- Compensação (*Compensating*)
 - Substituir ou compensar controlos principais que não podem ser implementados diretamente
 - Segmentação, múltiplos backups
- Recuperação (*Recovery*)
 - Restaurar operações e garantir a continuidade do negócio após um incidente.
 - Backup/restore, Plano de Continuidade de Negócio (Business Continuity Plan)



Categorias e Tipos de Controlos

	Prevenção	Deteção	Correção
Físicos	- Vedações - Portões - Fechaduras	- CCTV	- Reparar fechaduras - Reparar janelas - Reemitir cartões de acesso
Técnicos	- Firewall - Autenticação - Antivírus	- Deteção de intrusões - Alarmes - Honeypots	- Correção de vulnerabilidades - Reiniciar sistemas - Repor VMs - Remover Vírus
Administrativos	- Cláusulas Contratuais - Separação de obrigações - Classificação de Informação	- Revisão de matrizes de acesso - Auditorias	- Implementar planos de continuidade de negócio - Implementar plano de resposta a incidentes

- Nesta disciplina o enfoque maior vai ser nos controlos técnicos



O triplo A (AAA)

- Três controlos essenciais usados para gerir os acessos e responsabilidades a dados, redes e sistemas
- Autenticação
 - Authentication
- Autorização
 - Authorization
- Responsabilização
 - Accountability





Autenticação

- Processo para confirmar que um interlocutor é quem ele diz ser.



- Métodos:
 - Algo que sabes (passwords, PINs, ...)
 - Algo que tens (cartão, token, app, ...)
 - Algo que és (biometria: impressões digitais, reconhecimento facial, ...)
- Tendências: autenticação multifator (MFA), passwordless, Single Sign-On (SSO).

- Ligação com Objetivos da Segurança:
 - Confidencialidade e integridade: só utilizadores legítimos conseguem aceder ou alterar.
 - Autenticidade → garante que a identidade corresponde à entidade verdadeira (ex.: certificado SSL de um site).



Identificação versus Autenticação

The diagram illustrates the concepts of Identification and Authentication using a login form and an email interface.

Identification: A large grey arrow points from the email interface to the login form. The email interface shows a welcome message for "EricConrad" and a list of messages. The login form shows the username "deckard" and the email domain "@ericconrad.com".

Authentication: A large grey arrow points from the login form to the email interface. The login form shows the password field (masked with dots), a "Stay signed in" checkbox, and a "Sign in" button. The email interface shows a "New! One-step" message and a link to "Check out these example sites: !".

Login Form Details:

- Sign in to your account at **EricConrad**
- Username:
-
- Password:
- ☒ Stay signed in
-
- [Can't access your account?](#)

Email Interface Details:

- Less spam, plenty of space
- Welcome to your email for EricConrad
- Identificação
- Keep any message you might want to keep
- Send mail, read new messages
- New! One-step
- Building a site is as simple as editing a document
- Check out these example sites: !



Autenticação versus Autenticidade

- Autenticação

- Processo técnico de verificar a identidade de um utilizador ou sistema.
- Pergunta: “És quem dizes ser?”
- Exemplo: login com password + MFA.

- Autenticidade

- Propriedade que garante que algo ou alguém é real e legítimo
- Pergunta: “É verdadeiro? Veio mesmo desta fonte?”
- Exemplo: assinatura digital em contrato ou certificado SSL de um site.



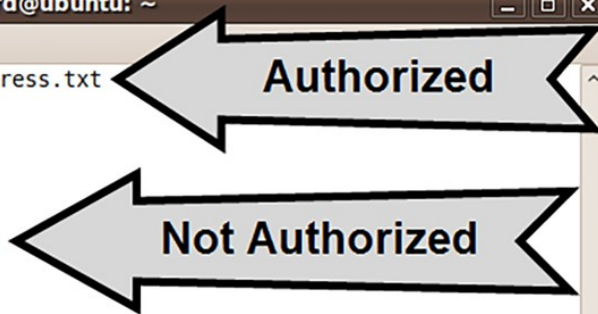
Autorização

- Definir o que o utilizador autenticado pode fazer



- Autorização é o processo que, depois da autenticação, determina a que recursos o utilizador pode aceder e que operações pode executar
- Modelos principais:
 - DAC (Discretionary Access Control)
 - MAC (Mandatory Access Control)
 - RBAC (Role Based Access Control)
 - ABAC (Attribute-Based Access Control)

```
deckard@ubuntu: ~  
File Edit View Terminal Help  
deckard@ubuntu:~$ cat sebastian-address.txt  
J.F. Sebastian  
Bradbury Apartments  
Ninth Sector  
N.F. 46751  
deckard@ubuntu:~$ cat /etc/shadow  
cat: /etc/shadow: Permission denied  
deckard@ubuntu:~$
```





Modelos de Autorização (1)

- DAC (Discretionary Access Control)
 - Proprietário do recurso define permissões.
 - Ex.: permissões em ficheiros no Windows/Linux (rw-r—r--).
 - Vantagem: flexível. Desvantagem: pode ser caótico.
- MAC (Mandatory Access Control)
 - Baseado em políticas fixas, não alteráveis pelo utilizador.
 - Usado em ambientes militares/altamente sensíveis (classificação: Confidencial, Secreto, Top Secret).



Modelos de Autorização (2)

- RBAC (Role-Based Access Control)
 - Acesso com base em papéis/funções (admin, editor, leitor).
 - Ex.: sistemas empresariais → contabilidade, RH, TI.
 - É o mais usado em ambientes corporativos.
- ABAC (Attribute-Based Access Control)
 - Baseado em atributos do utilizador, recurso e contexto.
 - Ex.: “Um médico pode aceder ao histórico clínico de pacientes do seu hospital durante o horário de serviço”.
 - Mais flexível e moderno, mas mais complexo.



Responsabilização/Auditoria (Accountability)

- Não basta autenticar e autorizar → é preciso registar e monitorizar
- Responsabilização é o processo de recolher, analisar e proteger registos (logs) das ações realizadas em sistemas para:
 - Prevenir e detetar abusos.
 - Provar responsabilidades.
 - Garantir conformidade legal e regulatória.
- O que se audita?
 - Logins: tentativas bem-sucedidas e falhadas.
 - Acessos a ficheiros e bases de dados: leitura, escrita, alteração, eliminação.
 - Alterações de configuração: privilégios, permissões, políticas.
 - Eventos de segurança: ataques, malware, acessos suspeitos.
 - ...



ACCOUNTABILITY



Mecanismos de Responsabilização

- Logs de sistema (Linux: /var/log/, Windows Event Viewer).
 - Logs de aplicação (bases de dados, servidores web).
 - Soluções centralizadas:
 - SIEM (Security Information and Event Management).
 - SOC (Security Operations Center).
 - Proteção dos logs:
 - Cifrar, replicar, tornar imutáveis → para evitar adulteração.
 - Exemplos Reais:
 - Caso de fraude interna: logs provam que um funcionário acedeu a dados de clientes fora do horário de trabalho.
 - Ataques externos: logs mostram tentativas de login de endereços IP suspeitos.
 - Incidentes legais: em auditorias RGPD, logs servem como prova de que os dados foram tratados corretamente.
-



Atividade

- Analise os registos de log abaixo e responda em grupo às questões propostas. Este exercício serve para compreender a importância da auditoria na deteção de incidentes e na atribuição de responsabilidades.

10/09 12:31 – Login falhado (utilizador: admin, IP: 192.168.1.23)
10/09 12:32 – Login falhado (utilizador: admin, IP: 192.168.1.23)
10/09 12:35 – Login bem-sucedido (utilizador: admin, IP: 192.168.1.23)
10/09 12:40 – Ficheiro notas2023.db alterado (utilizador: admin)
10/09 12:42 – Ficheiro notas2023.db consultado (utilizador: aluno123)
10/09 12:50 – Conta bloqueada após 5 tentativas falhadas (utilizador: aluno999)

- Perguntas para Discussão:
 - Que eventos suspeitos conseguem identificar nos logs apresentados?
 - Que objetivos da segurança (CIA, Autenticidade, Não Repúdio) estão em causa?
 - Que ações poderiam ser tomadas para mitigar os riscos?
 - Como se poderia proteger estes registos de auditoria contra adulteração ou eliminação?



Responsabilização

- De que serve termos logs se qualquer administrador pode apagá-los?
 - Perdemos a integridade dos registos: não há garantias de que os eventos são reais.
 - Compromete-se o não repúdio: um utilizador malicioso pode apagar rastros das suas ações.
 - Afeta investigações forenses e auditorias: não é possível reconstruir incidentes ou atribuir responsabilidades.
 - Pode invalidar conformidade legal: regulamentos como o RGPD ou PCI-DSS exigem logs protegidos.
- **Responsabilização só funciona se os logs forem íntegros e imutáveis.**
 - Logs sem proteção são praticamente inúteis em termos de segurança.



Logs: Boas Práticas

- Centralização dos logs em servidores dedicados
 - não no sistema auditado.
- Assinatura digital e/ou hashing dos registos para detetar adulteração.
- Permissões restritas
 - administradores de sistemas ≠ administradores de auditoria.
- Soluções WORM (Write Once, Read Many)
 - logs gravados não podem ser apagados.



AAA: Conclusão

- AAA = pilares práticos da segurança.
- Autenticação: garante quem és.
- Autorização: garante o que podes fazer.
- Responsabilização: regista o que fizeste de forma a não o poderes negar.



Bibliografia

- Risco Empresarial e Cibersegurança; António Miguel, PhD; FCA; 2024
- Introdução à Cibersegurança, 2ª Edição; Mário Antunes e Baltazar Rodrigues; FCA; 2022
- Segurança de Rede, Defesa Cibernética e Operações; Daniel Ferreira; FCA; 2024
- Introdução à Criptografia; Fernando Boavida e Mário Bernardes; FCA; 2019
- Segurança em Redes Informáticas, 6ª Edição; André Zúquete; FCA; 2021



Questões?

